

MITRE ATT&CK® RESEARCH INTERNSHIP
Group Leader Selection Program
Cyber Threat Intelligence Research Report — v2 (All 27 Fields)

INTERN DETAILS

Intern ID: 2173
Name: Mehul Bhume
Campaign: Operation Digital Eye (Program No. 73)
Software Range: S0730 – S0739 (10 Entries)
Submission Date: 15 May 2026
ATT&CK Version: v19 – April 2026
Research Platform: <https://attack.mitre.org>
Document Version: v2 – All 27 Fields (Per Program Directive)

PART 1 – CAMPAIGN RESEARCH

Campaign: Operation Digital Eye | Program No. 73 | MITRE ATT&CK v19

1.1 COMPLETE INTELLIGENCE PROFILE — ALL 27 FIELDS

Campaign ID: C0073 (MITRE v19) | Program No. 73
Threat Actor / APT: Unattributed China-Nexus APT | Suspected PRC Ministry of State Security | Overlap: Stately Taurus / Mustang Panda
Campaign Name: Operation Digital Eye
Activity Period: First Seen: Late June 2024 (UTC) | Last Seen: Mid-July 2024 (UTC) | Duration: ~3 weeks
Software Used: PHPsert | bK2o.exe (mimCN) | sqlmap | code.exe (VS Code) | winsw.exe | CreateDump | local.exe | GetUserInfo
Target Country: Italy, Spain, Portugal, Greece (Southern & Eastern Europe)
Victim Country: Italy, Spain, Portugal, Greece — Large B2B IT Service Providers
Target Industry: IT Services / MSPs | Cybersecurity | Infrastructure Management | Cloud Services | Data Centers
Malware / Tool Used: PHPsert webshell | mimCN/bK2o.exe | sqlmap | code.exe | winsw | CreateDump | SSH authorized_keys backdoor
IOC Type: File Hash (SHA-256) | Process Name | Network Domain | File Artifact | Registry Key | User-Agent | SSH Key
IOC Value: bK2o.exe | PHPsert webshell | code.exe | do.exe/do.bat | tunnels.api.tunnel.microsoft.com | vscode.dev | sqlmap UA
File / Hash Type: PE32 EXE: bK2o.exe | PHP: PHPsert | PE32 MS-signed: code.exe | BAT: do.bat | SHA-256 via SentinelOne report
IP Address: Azure dynamic IPs (C2) | M247 Europe relay IPs (Romania/UK) | Victim: Southern European MSP IP ranges

IP Geolocation: C2: Microsoft Azure EU (Ireland/Netherlands) | Relay: M247 Europe (Romania, UK) | Victims: Southern Europe
Domain / DNS: tunnels.api.tunnel.microsoft.com | vscode.dev | github.com (OAuth tunnel auth)
Infrastructure: Microsoft Azure Dev Tunnels | M247 European hosting (relay) | Victim web/DB servers | SSH backdoors
Attack Vector: SQL Injection via sqlmap → PHPsert webshell → LSASS dump → Pass-the-hash → VS Code tunnel C2
TTPs: T1190 | T1505.003 | T1003.001 | T1550.002 | T1219 | T1665 | T1021.001 | T1082 | T1016 | T1083 | T1078 | T1036 | T1070.004 | T1560
Persistence: PHPsert webshell | VS Code tunnel as Windows service (winsw) | SSH authorized_keys backdoor
Privilege Escalation: CreateDump extracts LSASS memory (T1003.001) | SAM via reg save | Pass-the-hash via bK2o.exe (T1550.002)
C2 Communication: VS Code Remote Tunnels → Microsoft Azure (HTTPS 443) | GitHub OAuth auth | Blends with legitimate dev traffic
Data Exfiltration: Campaign disrupted before exfiltration. Likely: VS Code tunnel file transfer from %SystemRoot%\Temp
Campaign Objective: Cyberespionage: Establish footholds in B2B IT providers → supply chain compromise → downstream client access
Attribution: MEDIUM — mimCN links to Chinese APT ecosystem | Simplified Chinese code comments | PRC victimology match
Threat Severity: CRITICAL — Novel C2 evades traditional defenses | Supply chain risk for hundreds of downstream clients
Detection Source: SentinelLABS & Tinexta Cyber (Dec 2024) | MITRE ATT&CK v19 (Apr 2026)
Analyst Notes: First documented Chinese APT use of VS Code Remote Tunnels for C2. PHPsert contained Simplified Chinese code comments. mimCN shared across multiple Chinese APT clusters via digital quartermaster (corroborated by I-Soon leak Feb 2024).

1.2 ATTACK FLOW (KILL CHAIN)

PHASE 1 – INITIAL ACCESS (T1190)

SQL injection via sqlmap against internet-facing web/database servers. Automated vulnerability detection and exploitation.

PHASE 2 – FOOTHOLD (T1505.003)

PHPsert PHP webshell deployed. Named using local language to appear legitimate. Working dirs: %SystemRoot%\Temp, %ProgramData%\Visual Studio Code.

PHASE 3 – RECONNAISSANCE (T1082 | T1016)

GetUserInfo, ping, local.exe used. System info, user groups, network topology mapped.

PHASE 4 – CREDENTIAL ACCESS (T1003.001 | T1550.002)

CreateDump (do.exe) extracts LSASS memory. reg save dumps SAM database. mimCN (bK2o.exe) used for pass-the-hash attacks.

PHASE 5 – LATERAL MOVEMENT (T1021.001 | T1550.002)

RDP connections across internal network. Pass-the-hash via bK2o.exe. No plaintext passwords needed.

PHASE 6 – C2 PERSISTENCE (T1219 | T1665)

VS Code Remote Tunnel via code.exe run as Windows service (winsw). SSH authorized_keys backdoor. Azure infrastructure camouflages C2 traffic.

PHASE 7 – DISRUPTED

Detected and disrupted by SentinelLABS & Tinexta Cyber before data exfiltration could occur.

1.3 FULL ATT&CK TTP MAPPING

T1190	Initial Access	Exploit Public-Facing Application — SQL injection via sqlmap
T1505.003	Persistence	Web Shell — PHPsert PHP webshell for persistent server access
T1003.001	Credential Access	LSASS Memory — CreateDump + LSASS extraction; SAM via reg save
T1550.002	Lateral Movement	Pass the Hash — bK2o.exe (mimCN) across internal network
T1021.001	Lateral Movement	RDP — Remote Desktop Protocol between compromised hosts
T1219	C2	Remote Access Software — VS Code Remote Tunnels abused for C2
T1665	C2	Hide Infrastructure — Azure cloud camouflages C2 traffic
T1082	Discovery	System Information Discovery — GetUserInfo, Windows built-ins
T1016	Discovery	Network Configuration Discovery — topology mapping
T1083	Discovery	File and Directory Discovery on compromised systems
T1036	Stealth	Masquerading — PHPsert named in local language
T1070.004	Defense Impairment	File Deletion — remove forensic traces
T1078	Stealth	Valid Accounts — harvested credentials for legitimate-looking access
T1560	Collection	Data staged in working directories (disrupted before exfil)

1.4 CAMPAIGN IOC TABLE

IOC Type	IOC Value	Hash Type	IP Address	IP
Geolocation	Domain	Infra Type		
File - EXE	bK2o.exe (mimCN Mimikatz)	PE32 Executable	N/A - local	
Southern Europe MSP	N/A	Endpoint artifact		

File - PHP	PHPsert webshell (assert-based)	PHP Script	N/A - web server
Southern Europe MSP	N/A	Web server artifact	
File - EXE	code.exe (VS Code portable)	PE32 MS-signed	N/A - local
Victim host	N/A	C2 tool	
File - EXE	do.exe (CreateDump renamed)	PE32 .NET EXE	N/A - local
Victim host	N/A	Credential tool	
File - BAT	do.bat (execute + delete CreateDump)	Batch Script	N/A
Victim host	N/A	Cleanup script	
Network - FQDN	tunnels.api.tunnel.microsoft.com	FQDN / HTTPS	Azure
dynamic IPs	Microsoft Azure EU	tunnels.api.tunnel.microsoft.com	C2 - Cloud tunnel
Network - FQDN	vscode.dev (browser tunnel)	FQDN / HTTPS	Azure dynamic
IPs	Microsoft Azure EU	vscode.dev	C2 browser access
Network - FQDN	github.com (OAuth tunnel auth)	FQDN / HTTPS	GitHub CDN
IPs	US/Global CDN	github.com	Auth relay
User-Agent	sqlmap/1.x.x (automated SQLi)	HTTP Header	Attacker IP
(proxied) Unknown - proxied	N/A	Initial access tool	
File - Config	winsw.exe XML config (VS Code svc)	XML Config	N/A
Victim host	N/A	Persistence artifact	
SSH Key	authorized_keys (attacker pub key)	SSH Public Key	N/A
Victim host	N/A	SSH backdoor	
Relay Infra	M247 Europe (hosting provider)	IPv4 Hosting	M247 EU IP range
Romania / UK (M247)	M247 AS provider	Relay/proxy node	

1.5 DETECTION & DEFENSIVE RECOMMENDATIONS

1. Monitor VS Code Tunnels

Alert on code.exe with 'tunnel' parameter on servers; connections to tunnels.api.tunnel.microsoft.com from non-developer machines; winsw running VS Code as service.

2. WAF / SQL Injection Detection

Detect sqlmap User-Agent strings; anomalous SQL patterns in DB logs; mass error responses from web servers.

3. Credential Protection

Enable Credential Guard; monitor LSASS access (Sysmon Event 10); alert on reg save HKLM\SAM; detect Mimikatz signatures (YARA: sequence f7f1 85d2 7406 2bca).

4. Webshell Detection

PHP assert() usage on web servers; files with local-language names in web root; unexpected file creation in %SystemRoot%\Temp by web server process.

5. Lateral Movement Alerts

Pass-the-hash (Event ID 4624 Type 3 with NTLM); anomalous RDP sessions between servers; do.* file naming pattern.

6. Supply Chain Hardening

Audit all B2B IT provider access; zero-trust segmentation; require MFA for all MSP remote access.

7. Threat Intel Feeds

Subscribe to mimCN IOC feeds; monitor Operation Soft Cell / Tainted Love TTP overlaps; track Chinese APT quartermaster tooling.

PART 2 – SOFTWARE RESEARCH

Software Range: S0730 – S0739 | 10 Entries | All 27 Fields

S0730 – WarzoneRAT

Type: Malware – Remote Access Trojan (RAT) / MaaS
Threat Actor: TA2541 (GOLD ULRICK) | Multiple financially-motivated actors
Platforms: Windows (x86/x64)
First Seen: 2018 (MaaS launch); active campaigns 2020–2024
Victim Country: Italy, Spain, Portugal, Greece; US, Middle East
Target Sector: Aviation, Aerospace, Defense, Manufacturing
Infrastructure: VPS-hosted C2 (bulletproof hosting)
Attack Vector: Spearphishing email with malicious attachment
Persistence: Registry Run Key (T1547.001)
Privilege Escal: UAC Bypass (T1548.002)
C2: Custom TCP encrypted protocol (ports 5200/5100)
Exfiltration: Exfiltration over C2 channel (T1041)
Objective: Remote access, credential theft, espionage, financial fraud
Attribution: HIGH – Well-documented MaaS; multiple actor attribution
Severity: CRITICAL

Description:

WarzoneRAT (also: Ave Maria RAT) is a commercially available C++ RAT sold as Malware-as-a-Service on cybercrime forums. Capabilities: keylogging, webcam hijack, credential theft, remote desktop, file management, reverse proxy. Custom TCP C2. Distributed via spearphishing.

TTPs:

T1566.001 | Initial Access | Spearphishing Attachment — malicious email attachments deliver loader
T1059.003 | Execution | Windows Command Shell — CMD for post-compromise commands
T1547.001 | Persistence | Registry Run Keys — HKCU\...\CurrentVersion\Run for autostart
T1548.002 | Privilege Escalation | Bypass UAC — elevate to administrator
T1027 | Defense Evasion | Obfuscated Files — packed executable to evade AV

T1555.003 | Credential Access | Browser Credentials — Chrome, Firefox, Edge password extraction
T1056.001 | Collection | Keylogging — full keyboard input capture
T1095 | C2 | Non-App Layer Protocol — custom encrypted TCP ports 5200/5100
T1041 | Exfiltration | Exfil over C2 Channel

IOCs:

- File Hash (SHA-256): Multiple variants (see VirusTotal WarzoneRAT) | PE32 EXE | Various C2 IPs | Randomized domains
- Registry Key: HKCU\...\Run\[random name] | Registry Value
- Network Port: TCP/5200, TCP/5100 (C2) | Bulletproof VPS IPs

Detection: Unusual outbound TCP on ports 5200/5100; registry Run key creation by non-system processes; browser DB access from unknown processes; UAC bypass Event ID 4688.

References: attack.mitre.org/software/S0730 | CISA AA23-025A | Cisco Talos WarzoneRAT 2023

S0731 – WhisperGate

Type: Malware – Destructive Wiper / Pseudo-Ransomware
Threat Actor: DEV-0586 / Cadet Blizzard (Russian GRU – Microsoft & US Govt attributed)
Platforms: Windows
First Seen: January 2022 – Ukraine (days before Russian military invasion)
Victim Country: Ukraine
Target Sector: Government, Military, Critical Infrastructure, Energy, Finance
Infrastructure: Attacker staging servers; Discord CDN abuse
Attack Vector: Exploitation of public-facing applications
Persistence: N/A – one-time destructive payload (MBR overwrite)
Privilege Escal: MBR overwrite grants full disk control
C2: None – standalone wiper
Exfiltration: Destruction via MBR wipe + file overwrite (no exfiltration)
Objective: Cyberwarfare – destabilize Ukrainian infrastructure ahead of military invasion
Attribution: HIGH – Attributed by Microsoft, US Government, Five Eyes to Russian GRU
Severity: CRITICAL

Description:

WhisperGate is a two-stage destructive wiper masquerading as ransomware. Stage 1 overwrites the MBR. Stage 2 downloads a file corruptor from Discord CDN overwriting 200+ file extensions with random bytes. No decryption exists — purely destructive cyberweapon deployed ahead of Russia's invasion of Ukraine.

TTPs:

T1190 | Initial Access | Exploit Public-Facing Application
T1059.001 | Execution | PowerShell — downloads Stage 2 from Discord CDN
T1036.005 | Stealth | Masquerading — fake ransomware note misleads responders

T1027 | Defense Evasion | Obfuscated Files — obfuscated Stage 2 downloader
T1561.002 | Impact | Disk Structure Wipe — MBR overwrite renders systems unbootable
T1485 | Impact | Data Destruction — overwrites 200+ file extensions with random bytes

IOCs:

- File Hash (SHA-256):
a196c6b8ffcb97ffb276d04f354696e2391311db3841ae16c8c9f56f36a38e92 | PE32 EXE Stage 1
- File Hash (SHA-256):
dcbbae5a1c61dbbbb7dcd6dc5dd1eb1169f5329958d38b58c3d26961bf3c0e35 | PE32 EXE Stage 2
- Network URL: cdn.discordapp.com (Stage 2 download) | HTTPS | Discord CDN IPs
- File Artifact: Fake ransom note (TXT file) on victim host

Detection: Monitor for MBR modification (Sysmon); PowerShell downloading from Discord CDN; mass file write activity; Event ID 4657.

References: attack.mitre.org/software/S0731 | Microsoft MSTIC Jan 2022 | CISA AA22-057A

S0732 – Pikabot

Type: Malware – Modular Loader / Backdoor
Threat Actor: TA577 (Proofpoint) | QakBot replacement post-2023 takedown
Platforms: Windows
First Seen: Early 2023; major activity Q1–Q4 2023
Victim Country: USA, Europe, Australia
Target Sector: Finance, Healthcare, Technology, Retail
Infrastructure: Bulletproof VPS; IP-direct C2 (no domain)
Attack Vector: Thread-hijacking phishing email campaigns
Persistence: Registry Run Key (T1547.001)
Privilege Escal: UAC bypass via process injection context
C2: Encrypted HTTPS to hardcoded IPs (ports 443, 2967, 2222)
Exfiltration: Cobalt Strike staging for ransomware deployment
Objective: Malware distribution; Cobalt Strike delivery for ransomware pre-positioning
Attribution: HIGH – Well-attributed to TA577 across multiple vendors
Severity: CRITICAL

Description:

Pikabot is a sophisticated modular loader operated by TA577. Distributes Cobalt Strike and other payloads. Heavy anti-analysis: anti-debugging, anti-sandbox, anti-VM. Communicates via encrypted HTTPS to hardcoded C2 IPs. Distributed via thread-hijacking phishing campaigns.

TTPs:

T1566.001 | Initial Access | Spearphishing — thread-hijacking with malicious ZIP (LNK/JS)

T1497 | Defense Evasion | Virtualization Evasion — anti-sandbox, anti-VM, anti-debug checks
T1055 | Execution | Process Injection — shellcode and DLL injection
T1547.001 | Persistence | Registry Run Key — autostart persistence
T1071.001 | C2 | Web Protocols — encrypted HTTPS to hardcoded IPs
T1059.007 | Execution | JavaScript — JS dropper in initial ZIP executes loader chain

IOCs:

- File: Pikabot loader DLL (random name) | PE32 DLL | Hardcoded C2 IPs | No domain – IP C2
- Network: HTTPS on port 443/2967/2222 | Bulletproof VPS
- File: ZIP with LNK or JS dropper
- Email: Thread-hijacked reply chain | Spoofed sender domain

Detection: ZIP attachments with LNK/JS; HTTPS from non-browser processes on unusual ports; process injection chains.

References: attack.mitre.org/software/S0732 | Proofpoint TA577 2023 | Elastic Security | Zscaler ThreatLabz

S0733 – SocGholish (FakeUpdates)

Type: Malware – JavaScript Downloader / Initial Access Framework
Threat Actor: Evil Corp (TA543) | UNC2628 | Multiple ransomware precursor actors
Platforms: Windows, macOS
First Seen: 2017 (active); major campaigns 2020–2024
Victim Country: USA, Europe, Australia, Canada
Target Sector: Finance, Healthcare, Legal, Manufacturing, Government
Infrastructure: Compromised websites; attacker C2 VPS
Attack Vector: Drive-by download via compromised website (watering hole)
Persistence: Via delivered secondary payload (Cobalt Strike/NetSupport)
Privilege Escal: Via Cobalt Strike secondary payload
C2: HTTPS C2 with domain rotation; CDN-like domains
Exfiltration: Via secondary payload (data theft + ransomware)
Objective: Initial access broker; ransomware pre-positioning (LockBit, WastedLocker, Hive)
Attribution: HIGH – Multiple vendors attribute to Evil Corp / UNC2628
Severity: CRITICAL

Description:

SocGholish (FakeUpdates) is a JS-based malware framework distributed via drive-by downloads on compromised websites. Visitors see fake browser update popups delivering JS payloads. Performs system recon then delivers Cobalt Strike, NetSupport, or ransomware. Linked to LockBit, WastedLocker, Hive ransomware families.

TTPs:

T1189 | Initial Access | Drive-by Compromise — watering hole on compromised websites
T1059.007 | Execution | JavaScript — JS payload spawns wscript.exe/PowerShell

T1036.001 | Stealth | Masquerading — fake Chrome/Firefox/Edge browser update
T1082 | Discovery | System Info — collects OS, domain, AV info before payload delivery
T1071.001 | C2 | Web Protocols — HTTPS C2 with domain rotation
T1021.001 | Lateral Movement | RDP — used post-compromise after Cobalt Strike delivery

IOCs:

- JS Artifact: Fake update JS (obfuscated) | Attacker C2 IPs | Rotated attacker domains
- Process: wscript.exe spawned from browser process
- Network: HTTPS to attacker C2 | Frequently rotated domains
- File: Large .zip from CDN-like domain

Detection: Browser spawning wscript.exe/PowerShell; JS downloads from non-browser user-agent; large ZIP from non-update domains; Cobalt Strike secondary payload activity.

References: attack.mitre.org/software/S0733 | CrowdStrike FakeUpdates | eSentire TI 2024 | CISA #StopRansomware

S0734 – Neoichor

Type: Malware – Backdoor
Threat Actor: APT37 / Reaper / Group 123 (North Korean – Reconnaissance General Bureau)
Platforms: Windows
First Seen: 2021
Victim Country: South Korea, Japan, Vietnam
Target Sector: Government, Military, Defense, Media, NGOs, Human Rights
Infrastructure: APT37-controlled VPS (Asia-Pacific region)
Attack Vector: Spearphishing / Watering hole
Persistence: Registry Run Key (T1547.001)
Privilege Escal: N/A – runs with user-level access
C2: HTTP with Base64-encoded communications
Exfiltration: Exfiltration over HTTP C2 channel
Objective: Espionage against South Korean targets; credential and intelligence collection
Attribution: HIGH – Multiple vendors attribute to DPRK APT37
Severity: HIGH

Description:

Neoichor is a backdoor attributed to APT37, a North Korean state-sponsored group targeting South Korean government, military, defense, media, and human rights organizations. Establishes persistence, collects system info, and executes C2-issued commands. HTTP communications with Base64-encoded data.

TTPs:

T1547.001 | Persistence | Registry Run Key — autostart via HKCU Run key
T1059.003 | Execution | Windows Command Shell — C2 command execution via cmd.exe

T1082 | Discovery | System Info — OS version, username, hostname, architecture
T1071.001 | C2 | Web Protocols — HTTP C2 with Base64-encoded request/response
T1140 | Defense Evasion | Deobfuscate/Decode — Base64 encoding/decoding of C2 comms
T1041 | Exfiltration | Exfil over C2 — system data via HTTP channel

IOCs:

- File: Neoichor EXE (varied names) | PE32 EXE | APT37 C2 IPs (Asia-Pacific) | APT37 domains
- Registry: HKCU\...\Run\[persistence key]
- Network: HTTP POST with Base64 body | port 80 or 8080
- User-Agent: Custom UA string in HTTP requests

Detection: HTTP POST with Base64 body to unusual domains; Registry Run key creation; anomalous cmd.exe spawning from non-system processes.

References: attack.mitre.org/software/S0734 | ESET APT37 Report | AhnLab ASEC | Mandiant APT37

S0735 – Shark RAT

Type: Malware – Remote Access Trojan
Threat Actor: South Asian APT actors; government and military targeting
Platforms: Windows
First Seen: 2020
Victim Country: India, Pakistan, Afghanistan, Bangladesh
Target Sector: Government, Military, Defense
Infrastructure: VPS-hosted C2 (South Asia region)
Attack Vector: Spearphishing with malicious attachment
Persistence: Registry Run Key (T1547.001)
Privilege Escal: Runs with user-level privileges
C2: Custom encrypted TCP protocol
Exfiltration: Exfiltration via C2 channel (keystrokes, screenshots)
Objective: Espionage: surveillance of government/military personnel
Attribution: MEDIUM – Limited public attribution
Severity: HIGH

Description:

Shark RAT is a RAT used in targeted campaigns against government and military organizations in South Asia. Provides keylogging, screenshot capture, file management, and remote command execution. Plugin-based architecture for extensible functionality. Custom encrypted TCP C2.

TTPs:

T1547.001 | Persistence | Registry Run Key — autostart via registry or startup folder
T1056.001 | Collection | Keylogging — full keyboard input capture
T1113 | Collection | Screen Capture — periodic screenshots of victim desktop

T1095	C2	Non-App Layer Protocol — custom encrypted TCP
T1041	Exfiltration	Exfil over C2 — keystrokes and screenshots sent to C2
T1083	Discovery	File & Dir Discovery — file system browsing via RAT

IOCs:

- File: SharkRAT EXE (varied names) | PE32 EXE | South Asian VPS IPs | Actor domains
- Registry: HKCU\...\Run persistence key
- Network: Encrypted TCP outbound on non-standard port | South Asian VPS IPs

Detection: Unusual outbound TCP to non-standard ports; registry Run key; screenshot artifacts in temp directories; keylog files.

References: attack.mitre.org/software/S0735 | ThreatConnect South Asian APT Analysis

S0736 – QUIETEXIT

Type:	Malware – Backdoor / Proxy Tool
Threat Actor:	UNC3886 (Mandiant – China-nexus; targets VMware ESXi and Fortinet)
Platforms:	Linux / VMware ESXi / Fortinet FortiOS
First Seen:	2021–2022 (disclosed by Mandiant 2023)
Victim Country:	USA, Europe, Japan, Australia
Target Sector:	Government, Defense, Telecom, Technology, Critical Infrastructure
Infrastructure:	Compromised FortiGate/ESXi devices (no traditional C2 server)
Attack Vector:	Zero-day exploitation of FortiGate firewalls and VMware ESXi
Persistence:	Firmware-level backdoor on network appliances (T1505.003)
Privilege Escal:	Zero-day exploit for root access (T1068)
C2:	SSH tunneling / proxy through compromised appliances
Exfiltration:	Intelligence collection; lateral movement relay
Objective:	Long-term covert espionage; persistent access to network infrastructure
Attribution:	HIGH – Attributed by Mandiant to China-nexus UNC3886
Severity:	CRITICAL

Description:

QUIETEXIT is a sophisticated backdoor deployed by UNC3886 on network appliances and hypervisors where EDR cannot run. Installed on Fortinet FortiGate and VMware ESXi via zero-day exploits. Enables covert persistent access and proxies attacker traffic. UNC3886 specializes in appliance exploitation and is among the most sophisticated China-nexus threat actors.

TTPs:

T1505.003	Persistence	Web Shell — persistent backdoor on network appliance firmware
T1070.004	Defense Impairment	File Deletion — log deletion to erase compromise evidence
T1021.004	Lateral Movement	SSH — tunneling through compromised appliances
T1090	C2	Proxy — compromised appliance proxies attacker C2 traffic
T1068	Privilege Escal	Exploit Vulnerability — zero-day for root access on FortiOS/ESXi

T1016 | Discovery | Network Config — topology discovery through network devices

IOCs:

- File: QUIETEXIT binary (/tmp/ or /data/) | ELF Binary | UNC3886 C2 IPs (China-proxied)
- Network: Anomalous SSH tunnel from FortiGate/ESXi | SSH/TCP-22
- File: Modified FortiOS/ESXi config files
- CVE: CVE-2022-41328 (FortiOS path traversal)
- CVE: Multiple VMware ESXi zero-days

Detection: Network appliance integrity monitoring; filesystem audits on FortiGate/ESXi; anomalous SSH tunnels from network devices; firmware integrity hash checks.

References: attack.mitre.org/software/S0736 | Mandiant UNC3886 2023 | CISA ESXi Advisory | Fortinet PSIRT

S0737 – Sandman (LuaDream)

Type: Malware – Modular Backdoor
Threat Actor: Suspected China-nexus APT; overlaps with KEYPLUG infrastructure (Bronze Atlas/APT41)
Platforms: Windows
First Seen: 2023 (disclosed SentinelLABS & QGroup, September 2023)
Victim Country: Middle East, Europe, South Asia
Target Sector: Telecommunications, Government
Infrastructure: China-proxied VPS; overlaps KEYPLUG infrastructure
Attack Vector: Targeted intrusion (likely spearphishing)
Persistence: Windows service persistence (T1543.003)
Privilege Escal: Service-level privileges via Windows service installation
C2: Encrypted custom TCP; WinDivert network interception
Exfiltration: Espionage data via LuaDream plugin framework
Objective: Cyber espionage against telecom providers; long-term persistent access
Attribution: MEDIUM-HIGH – Unattributed but strong China-nexus indicators
Severity: CRITICAL

Description:

Sandman deploys LuaDream, a novel modular backdoor in LuaJIT that complicates detection and analysis. Targets telecom providers in Middle East, Europe, South Asia. Supports 18+ plugins: data collection, keylogging, C2. Uses WinDivert for network traffic interception. Infrastructure overlaps with Chinese APT KEYPLUG malware.

TTPs:

T1059 | Execution | Command & Scripting — LuaJIT executes modular backdoor plugins
T1543.003 | Persistence | Windows Service — LuaDream installed as persistent Windows service
T1056.001 | Collection | Keylogging — dedicated keylogger plugin among 18+ modules
T1027 | Defense Evasion | Obfuscated Files — LuaJIT bytecode obfuscation
T1071 | C2 | Application Layer — encrypted C2; WinDivert network interception

T1082 | Discovery | System Info — comprehensive system/user info via plugins

IOCs:

- File: LuaDream DLL / LuaJIT bytecode | PE32 DLL | KEYPLUG-overlap IPs | KEYPLUG infra domains
- Service: Malicious Windows service (LuaDream)
- File: WinDivert driver (network interception)
- Network: Encrypted custom TCP C2 | China-proxied VPS

Detection: LuaJIT process activity; WinDivert driver loading; unusual Windows services with LuaJIT dependencies; KEYPLUG C2 IOC overlaps.

References: attack.mitre.org/software/S0737 | SentinelLABS Sandman Sept 2023 | QGroup GmbH LuaDream

S0738 – HijackLoader (IDAT Loader)

Type: Malware – Modular Loader
Threat Actor: Multiple cybercrime actors; distributes Cobalt Strike, Danabot, RedLine, Lumma
Platforms: Windows
First Seen: 2023
Victim Country: USA, Europe, Global
Target Sector: Finance, Retail, Healthcare, Technology
Infrastructure: Bulletproof VPS; PNG hosting on legitimate file shares
Attack Vector: Phishing / Malvertising delivering malicious PNG
Persistence: Registry Run Key (T1547.001)
Privilege Escal: Process hollowing into system process (inherits privileges)
C2: HTTPS to attacker C2 for secondary payload delivery
Exfiltration: Via secondary payload (Danabot, RedLine, Lumma)
Objective: Initial access / payload delivery for financial fraud, credential theft, ransomware
Attribution: MEDIUM – Multiple actors use the same loader framework
Severity: HIGH

Description:

HijackLoader hides shellcode in PNG IDAT chunks using steganography. Features process hollowing, DLL hijacking, call stack spoofing, and reflective code loading. Widely used to deliver information stealers and banking trojans. Difficult to detect due to steganographic payload hiding and call stack spoofing.

TTPs:

T1027.003 | Defense Evasion | Steganography — shellcode hidden in PNG IDAT chunks
T1055.012 | Execution | Process Hollowing — payload injected into legitimate process
T1574.001 | Defense Evasion | DLL Hijacking — for execution and defense evasion
T1547.001 | Persistence | Registry Run Key — persistence across reboots
T1620 | Defense Evasion | Reflective Code Load — no disk-based module artifacts
T1036 | Stealth | Masquerading — disguises malicious PNG as legitimate image

IOCs:

- File: PNG with anomalous IDAT chunks
- Process: Process hollowing chains (svchost/explorer)
- Network: HTTPS C2 to payload servers | HTTPS/443 | Bulletproof VPS
- Memory: Reflective DLL injection artifacts

Detection: Memory forensics for process hollowing; PNG with executable IDAT data; call stack anomalies; DLL hijacking in system directories.

References: attack.mitre.org/software/S0738 | Zscaler ThreatLabz HijackLoader 2023 | Elastic Security

S0739 – FakeBat (EugenLoader / PaykLoader)

Type: Malware – Loader / Dropper (MaaS)
Threat Actor: Multiple cybercrime actors via MaaS; delivers IcedID, RedLine, Lumma, Carbanak
Platforms: Windows
First Seen: 2022 (major distribution 2023–2024)
Victim Country: USA, Europe, Global
Target Sector: Finance, Healthcare, Retail, Technology
Infrastructure: Malvertising ad networks; attacker VPS; DGA C2 domains
Attack Vector: Malvertising (Google/Bing Ads) + SEO poisoning
Persistence: Registry Run Key / Scheduled Task (T1547.001 / T1053.005)
Privilege Escal: Inherits user privileges; UAC bypass via signed MSIX
C2: HTTPS C2 with DGA domain rotation
Exfiltration: Via secondary payload (IcedID, Lumma, RedLine stealer)
Objective: Financial fraud, credential theft, ransomware delivery (initial access broker)
Attribution: HIGH – Multiple vendors; MaaS model widely documented
Severity: CRITICAL

Description:

FakeBat is a MaaS loader distributed via malvertising (Google/Bing Ads) and SEO poisoning targeting users searching for legitimate software. Uses code-signed MSIX installers to bypass SmartScreen. Delivers information stealers and banking trojans. One of the most widely observed malvertising-based loaders in 2023–2024.

TTPs:

T1583.008 | Initial Access | Malvertising — Google/Bing Ads redirect to trojanized downloads
T1553.002 | Defense Evasion | Code Signing — stolen certificates; signed MSIX bypasses SmartScreen
T1204.002 | Execution | Malicious File — user executes MSIX believing it is legitimate
T1036.001 | Stealth | Masquerading — impersonates Notepad++, 7-Zip, Zoom, Brave, AnyDesk
T1547.001 | Persistence | Registry Run Key — persistence after installation
T1071.001 | C2 | Web Protocols — HTTPS C2; DGA for domain rotation

IOCs:

- File: Signed MSIX installer (fake software) | MSIX Package | Attacker download server | Typosquatting domains
- Certificate: Code-signing cert (stolen/purchased) | X.509 Certificate
- Network: HTTPS C2 beaconing post-install | FakeBat C2 VPS IPs | DGA domains
- Ad URL: Google Ads → malicious download site | Typosquatting domains
- Process: AppInstaller.exe → unusual child process

Detection: Block MSIX from internet sources; AppInstaller.exe spawning unusual children; unknown CA code-signing cert; DNS to DGA domains; Google Ads pointing to non-official sites.

References: attack.mitre.org/software/S0739 | Mandiant FakeBat 2024 | Sekoia.io
EugenLoader | ESET Threat Report 2024

RESEARCH SUMMARY

Intern ID: 2173
Name: Mehul Bhume
Document: v2 – Complete 27-Field Intelligence Format (Per Program Directive)
Campaign: Operation Digital Eye | China-Nexus APT | June–July 2024 | Southern Europe
Software Entries: S0730 WarzoneRAT | S0731 WhisperGate | S0732 Pikabot | S0733 SocGhosh | S0734 Neoichor | S0735 Shark RAT | S0736 QUIETEXIT | S0737 Sandman | S0738 HijackLoader | S0739 FakeBat
ATT&CK Techniques: 35+ unique technique IDs documented
All 27 Fields: Campaign ID | Threat Actor | Name | Period | Software | Target Country | Victim Country | Industry | Malware | IOC Type | IOC Value | Hash Type | IP Address | IP Geo | Domain | Infra | Attack Vector | TTPs | Persistence | Privesc | C2 | Exfil | Objective | Attribution | Severity | Detection Source | Analyst Notes
ATT&CK Version: v19 – April 2026
Submission Date: 15 May 2026
Google Form: <https://forms.gle/X8QwrP5LS2q5vfRs5>

"Real capability appears through discipline, technical depth, research quality, and the ability to understand adversary behavior under real-world conditions."

— Intern ID 2173 | Mehul Bhume | MITRE ATT&CK Research Internship